



RAPPORT D'AUDIT QA

HotelScout Guinea v7

Test End-to-End Complet

Frontend + Backend API

Date	12/06/2026
Environnement	Dev local (SQLite), Next.js 16.1.3 + Turbopack
Testeur	Expert QA - 25 ans d'experience
Portee	8 pages frontend + 23 endpoints API

RESUME EXECUTIF

Indicateur	Valeur
Pages frontend testees	8
Endpoints API testes	23
Tests executes	68+
Bugs critiques	4
Bugs majeurs	9
Bugs mineurs	6
Vulnerabilites securite	4

Score global : 60/100 - INSUFFISANT

L'application presente des fonctionnalites solides mais souffre de problemes de validation des donnees, de securite (XSS stocke), et de bugs fonctionnels sur la page d'accueil. Les corrections prioritaires sont identifiees dans ce rapport.

AUDIT FRONTEND - PAGE PAR PAGE

1. Menu Reservation (Page d'accueil)

Test	Resultat	Details
Rendu initial		Page s'affiche correctement, hero, stats, hotels
Barre de recherche	PARTIEL	Le bouton Rechercher scroll vers les hotels au lieu de filtrer
Filtre region		Le filtre region ne filtre pas les hotels en vedette
Bouton Reserver	FAIL	Ne fonctionne pas - aucun dialogue ne s'ouvre
Mes reservations		Dialogue s'ouvre, planning fonctionnel
Planning etapes	PASS	Timeline verticale, marquage completed, ajout etapes
Donnees dynamiques		Hotels et stats viennent de l'API
Responsive mobile	PASS	Adaptation correcte sur mobile

2. Tableau de bord (Dashboard)

Test	Resultat	Details
Rendu initial		Stats, pipeline, regions - tout s'affiche
Navigation	PASS	Liens vers Prospects et Pipeline fonctionnels
Donnees dynamiques		Stats depuis /api/stats

3. Base Hotels

Test	Resultat	Details
Rendu initial		Tableau avec pagination
Recherche	PASS	Filtre par texte fonctionnel
Filtres (region, statut)		Tous les filtres fonctionnent
Tri colonnes	PASS	Tri par nom, region, score
Detail hotel		Dialogue avec infos completes
Export CSV	PASS	Telechargement fonctionnel
Entrees XSS visibles		Donnees malveillantes dans le tableau

4. Agent de Collecte

Test	Resultat	Details
Rendu initial		Page s'affiche
Lancer la collecte	PASS	Bouton avec loading state
Verifier les URLs		CRASH complet de l'application
Recherche	PARTIEL	Pas de resultat visible

5. Prospects HOT

Test	Resultat	Details
Rendu		Page s'affiche avec erreurs console
Bouton Actualiser	OK	Recharge les donnees
Checkbox selection		Premier clic ne toggle pas visuellement
Qualite des donnees	FAIL	Entrees malveillantes et doublons

6. Pipeline CRM

Test	Resultat	Details
Rendu		Liste plate des hotels
Stages pipeline	FAIL	Pas de vue Kanban ni colonnes
Changement de stage		Pas de feedback visible
Doublons	FAIL	Hotels dupliques dans la liste

7. Analyse IA

Test	Resultat	Details
Onglets providers		7 providers IA affiches
Chat sans cle API	WARN	Erreur "No AI providers configured"
Templates prompts		3 templates disponibles
Dropdown hotels	FAIL	Contient des entrees XSS/poubelle

8. Parametres

Test	Resultat	Details
Onglets		IA, Agence, Base de donnees
Sauvegarde cles API	OK	Entree, sauvegarde, suppression
Export CSV		Telechargement fonctionnel
Feedback actions	WARN	Pas de feedback pour enrichir/collecter

AUDIT BACKEND - API PAR API

1. GET /api/stats

Test	Resultat	Details
Appel sans params		200 - Structure complete et coherente
Performance	PASS	~13ms apres warm-up

2. GET /api/hotels

Test	Resultat	Details
Sans filtre		20 hotels, pagination correcte
Filtres (search, region, stars)	PASS	Tous fonctionnels
Protection injection		Prisma parametrise, safeParseInt
Tri (sortBy)	PASS	Whitelist des champs, default sur invalide

3. POST /api/hotels

Test	Resultat	Details
Creation valide		201 - Hotel cree correctement
XSS stocke	FAIL	<script> accepte et stocke sans sanitiser
Validation stars		Stars negatif ou >5 accepte
Validation longueur	FAIL	10000 caracteres accepte

4. PATCH /api/hotels/[id]

Test	Resultat	Details
Methode PATCH		405 - Seul PUT est implemente
PUT fonctionne	PASS	Mise a jour partielle OK

5. GET/POST /api/contacts

Test	Resultat	Details
Validation channel/direction		Enumere, 400 si invalide
Transaction atomique	PASS	contactCount et lastContactAt maj

6. POST /api/reservations

Test	Resultat	Details
Creation valide		201 avec 7 PlanningSteps auto
Validation dates	PASS	Passe et checkout<checkin rejetes
Validation email		"not-an-email" accepte
Validation guests	FAIL	0 ou negatif accepte

7. PATCH /api/reservations/[id]

Test	Resultat	Details
Status valide		Mise a jour fonctionne
Status invalide	FAIL	"invalid_status" accepte sans validation
ID inexistant		500 au lieu de 404

8. PATCH /api/planning

Test	Resultat	Details
Marquer completed		Auto-complete reservation si toutes faites
stepId inexistant	FAIL	500 au lieu de 404

9. POST /api/ai/chat

Test	Resultat	Details
Rate limiting		10 req/min avec headers X-RateLimit
Validation prompt	PASS	Max 10000 caracteres

ANALYSE DE SECURITE

Vulnerabilite	Severite	Endpoint	Details
XSS stocke		POST /api/hotels	HTML/JS non sanitisé, stocke tel quel
CORS wildcard	MOYENNE	Tous	Access-Control-Allow-Origin: * par default
CRON_SECRET optionnel		POST /api/cron/*	Accessible sans auth si CRON_SECRET absent
Cle chiffrement default	BASSE	security.ts	Cle codee en dur si ENCRYPTION_KEY absent

Recommandation principale : Implementer une sanitisation HTML cote serveur (DOMPurify ou equivalent) sur tous les champs texte avant insertion en base. Restreindre CORS a l'origine du frontend uniquement.

LISTE COMPLETE DES BUGS

Bugs critiques (P0)

ID	Bug	Localisation
C1	"Verifier les URLs" crash l'application	Agent de Collecte
C2	XSS stocke - entrees <script> dans POST /api/hotels	PAS de
C3	Donnees malveillantes polluent toutes les pages	Base de donnees
C4	Cle de chiffrement par defaut codee en dur	Security

Bugs majeurs (P1)

ID	Bug	Localisation
M1	Bouton "Reserver" non fonctionnel	Mechu Reservation
M2	Filtre region ne filtre pas les hotels	Mechu Reservation
M3	PATCH /api/hotels retourne 405	API Hotels
M4	Pas de validation status reservation	PATCH /api/reservations
M5	ID inexistant retourne 500 au lieu de 404	API Reservations/Planning
M6	Pas de validation email	POST /api/reservations
M7	Pas de validation stars [0-5]	POST /api/hotels
M8	Pas de validation longueur champs	POST /api/hotels
M9	Pipeline CRM sans vue Kanban	Pipeline CRM

Bugs mineurs (P2)

ID	Bug	Localisation
m1	Checkbox Prospects ne toggle pas	Prospects HOT
m2	Footer incomplet (4/8 pages)	Menu Reservation
m3	Pas de pagination GET /api/reservations	API Reservations
m4	Messages erreur fr/en melanges	Toutes les APIs
m5	Pas de feedback pour actions en attente	Parametres/Collecte
m6	Recherche n'affiche pas de resultat	Agent de Collecte

CORRECTIONS APORTEES

Les corrections suivantes ont ete appliquees suite a l'audit :

ID	Correction	Statut
C1	ErrorBoundary autour de CollectePage + gestion erreurs verify	
C2	stripHtml() ajoutée - suppression tags HTML/JS	FIXE
C3	Purge données malveillantes de la base	
M1	type="button" sur boutons Reserver + etat Dialog verifie	FIXE
M2	Filtre region applique sur tous les hotels (limit 100)	
M3	PATCH handler ajoute qui delegue a PUT	FIXE
M4	Validation status contre ALLOWED_STATUSES	
M5	Prisma P2025 catche specifiquement -> 404	FIXE
M6	Validation email par regex	
M7	Validation stars 0-5 avec message erreur	FIXE
M8	Validation longueur (name<=200, city<=100, region<=100)	
M2b	Recherche scroll vers hotels au lieu de naviguer	FIXE

POINTS POSITIFS

- Protection SQL injection : Prisma ORM parametre les requetes - aucune injection possible
- SSRF Protection : Module validateUrl() bloque les IPs internes
- Rate limiting : Implemente sur les endpoints sensibles (AI chat, providers, export)
- Chiffrement des cles API : AES-256-GCM avec keyHint masque
- safeParseInt : Protection NaN et bornes sur les parametres de pagination
- Whitelist sortBy : Previene injection via le tri
- Transactions atomiques : Contacts et pipeline utilisent des transactions Prisma
- CSV export avec BOM : Compatibilite Excel UTF-8
- Auto-complete planning : Logique correcte de passage a "completed"
- Security headers : X-Content-Type-Options, X-Frame-Options, X-XSS-Protection, Referrer-Policy
- Donnees 100% dynamiques : Plus aucune donnee statique/hardcodee
- Planning de bout en bout : 7 etapes automatiques, personnalisation, timeline visuelle

CORRECTIONS RESTANTES A EFFECTUER

Priorite	Correction	Effort
P2	CORS restrictif (origines autorisees)	Faible
P2	CRON_SECRET obligatoire en production	Faible
P2	Pagination GET /api/reservations	Faible
P2	Pipeline CRM - vue Kanban avec colonnes	Moyen
P2	Deduplication des hotels (contrainte unique)	Moyen
P3	Cohérence linguistique des erreurs (fr/en)	Faible
P3	Validation guests > 0	Faible
P3	ENCRYPTION_KEY obligatoire	Faible
P3	Footer navigation complet (8 pages)	Faible
P3	Feedback utilisateur pour actions en arriere-plan	Moyen